

15 · Riesgos y deuda técnica

Documentación de sistema

Versión analizada: **0.1.1+2**

Commit: **a7ebf2c**

Fecha del documento: **2026-08-27**

Documento generado desde el Markdown de **docs/system-documentation/** con **tool/build_system_documentation_pdf.py**. El Markdown es la fuente: no editar este PDF.

Contenido

1. Cómo leer la clasificación
2. Severidad alta
3. Severidad media
4. Severidad baja
5. Riesgos operativos, no de código
6. Decisiones que requieren validación humana
7. Lo que está bien y conviene no romper

Este documento es informativo. Ningún hallazgo se corrigió al escribirlo. Su propósito es que la decisión de arreglar, aceptar o descartar sea humana y explícita.

Cómo leer la clasificación

Campo	Escala
Severidad	Crítica · Alta · Media · Baja
Impacto	Qué se rompe o se expone si ocurre
Probabilidad	Alta · Media · Baja
Evidencia	Comprobado en el código, o inferencia
Prioridad	P1 (antes de la próxima entrega) · P2 (esta serie) · P3 (cuando toque)

Resumen: **19 hallazgos** — 0 críticos, 6 altos, 8 medios, 5 bajos.

Severidad alta

R-01 · Los fixtures de regresión no los ejecuta ninguna prueba

Aspecto	Detalle
Severidad	Alta · Probabilidad Alta · Prioridad P1
Ubicación	<code>fixtures/qr/manifest.json</code> , <code>test/</code>
Evidencia	Comprobado: <code>grep -rn "fixtures" test/</code> no devuelve nada. <code>verify_rootcause_contract.py</code> valida la <i>forma</i> del manifiesto, no ejecuta el motor contra él
Impacto	Los 12 casos declaran <code>expectedSeverity</code> , <code>expectedAction</code> , <code>mustInclude</code> y <code>mustExclude</code> , y nadie comprueba que el motor los cumpla. Un cambio de peso o de condición puede pasar el gate completo sin que nadie note la regresión
Recomendación	Añadir una prueba que lea el manifiesto, ejecute <code>QrInvestigationEngine.analyze</code> sobre cada carga y compare los cuatro campos. Coste estimado: una tarde. Es la mejora con mejor relación coste/beneficio del repositorio

R-02 · La migración del historial heredado no tiene prueba

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P1
Ubicación	<code>lib/services/history_repository.dart</code> , <code>_migrateLegacyHistory</code>

Evidencia	Comprobado: <code>history_repository_test.dart</code> solo cubre <code>replaceAll</code>
Impacto	Es el procedimiento con mayor riesgo de pérdida de datos del sistema: lee un origen en claro, lo respalda cifrado, convierte, verifica y borra el origen . Un error en el orden es irreversible
Recomendación	Pruebas para: origen ausente, origen no-lista, conversión correcta, verificación fallida que revierte, e idempotencia al repetir

R-03 · Los contactos de una vCard entran en el historial

Aspecto	Detalle
Severidad	Alta · Probabilidad Alta · Prioridad P1
Ubicación	<code>lib/services/content_interpreter.dart</code> , <code>_vcard</code> y <code>_mecard</code>
Evidencia	Comprobado: ninguno de los dos marca <code>sensitive: true</code>
Impacto	Nombre, teléfono, correo y dirección postal de terceros quedan guardados —cifrados, pero guardados— sin que la persona lo decida. La política declarada del producto excluye OTP, Wi-Fi, pagos e identidad; los contactos caen en un hueco
Recomendación	Decidir explícitamente: marcarlos sensibles, o documentar en la política de privacidad que los contactos sí se conservan. La decisión es del responsable del producto, no técnica

R-04 · La evidencia no está firmada

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/core/investigation/qr_evidence_exporter.dart</code>
Evidencia	Comprobado: <code>assurance: checksum-only-not-authenticated</code>
Impacto	Quien modifique el JSON puede recalcular <code>bundleHash</code> . Si alguien presenta una evidencia como prueba en un procedimiento, el checksum no acredita autoría ni integridad frente a un adversario
Mitigación actual	El propio campo lo declara, y la documentación lo repite
Recomendación	Firma asimétrica opcional, o anclaje externo del hash. Hasta entonces, no describirlo nunca como «evidencia firmada»

R-05 · La corrección de lectura de 0.1.1 no está probada en hardware

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P1

Ubicación	<code>mobile_scanner_engine.dart</code> , <code>scanner_screen.dart</code> , <code>inventory_screen.dart</code>
Evidencia	Comprobado: las pruebas añadidas verifican la configuración, no el comportamiento óptico
Impacto	Subir la resolución a 1920×1080 puede aumentar memoria y temperatura en gama baja. Nadie ha confirmado en un teléfono real que un QR lejano se lea, ni que la confirmación se oiga
Recomendación	Ejecutar las cuatro filas nuevas de la matriz de dispositivos en al menos un teléfono de gama baja y uno de gama alta antes de anunciar la corrección como verificada

R-06 · La pantalla del escáner no tiene pruebas

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/scanner/scanner_screen.dart</code> , 780 líneas
Evidencia	Comprobado: no hay ningún archivo de prueba para ella
Impacto	Concentra el filtro de repetición, la política de persistencia de contenido sensible, el ciclo de vida de la cámara y los lotes cancelables. La regla «un registro sensible nunca se guarda» vive aquí y no la comprueba ninguna prueba
Recomendación	Extraer la lógica sin interfaz —filtro de repetición y decisión de persistencia— a funciones puras y probarlas. El widget completo requiere cámara; sus reglas, no

Severidad media

R-07 · ScannerEngine filtra el tipo del paquete que abstrae

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/features/scanner/domain/scanner_engine.dart</code>
Evidencia	Comprobado: la interfaz expone <code>MobileScannerController</code> <code>get controller</code> y <code>ValueListenable<MobileScannerState></code>
Impacto	Un segundo motor no podría implementarla sin depender de <code>mobile_scanner</code> . La frontera «estable» no aísla lo que dice aislar
Recomendación	Al añadir un segundo motor, sustituir por un tipo propio de estado. Mientras haya una sola implementación, el coste de arreglarlo supera al beneficio

R-08 · El inventario no usa `ScannerEngine`

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/inventory/inventory_screen.dart</code>
Evidencia	Comprobado: construye <code>MobileScannerController</code> directamente
Impacto	Duplica el ciclo de vida, el manejo de errores y la configuración. La corrección de 0.1.1 tuvo que aplicarse dos veces , y una tercera pantalla con cámara la olvidaría
Recomendación	Migrar el inventario a <code>MobileScannerEngine</code> con su resolución propia

R-09 · Las banderas de capacidades no se leen

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/core/feature_flags/feature_flags.dart</code>
Evidencia	Comprobado: <code>grep -rn "featureFlags\" lib/</code> solo encuentra serialización
Impacto	Nueve booleanos que se guardan y se leen sin efecto. Un lector puede creer que activarlas hace algo
Recomendación	Conservarlas —el contrato de compatibilidad las menciona— y documentar en la interfaz que están reservadas. Ya está documentado en <code>FEATURE_FLAGS.md</code>

R-10 · La lista del historial muestra la carga sin ocultar

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/history/history_screen.dart</code>
Evidencia	Comprobado: el subtítulo incluye <code>item.rawValue</code> sin comprobar <code>hideSensitiveValues</code>
Impacto	La ocultación solo se aplica en la tarjeta de detalle. Una URL larga con parámetros queda visible en la lista, y en cualquier captura de pantalla
Mitigación	Los contenidos marcados sensibles no llegan al historial
Recomendación	Aplicar la misma política de ocultación en la lista

R-11 · Sin protección frente a capturas de pantalla

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	Todo el árbol de la interfaz
Evidencia	Comprobado: no hay FLAG_SECURE ni equivalente
Impacto	El conmutador de aplicaciones puede mostrar el resultado; una captura conserva un secreto
Mitigación	El bloqueo biométrico oculta el contenido al perder el primer plano, si está activado
Recomendación	Evaluar FLAG_SECURE en las pantallas de resultado e historial. Tiene coste: impide capturas legítimas para soporte

R-12 · RiskLevel duplica una fuente de verdad

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/core/security/scan_security_analyzer.dart</code>
Evidencia	Comprobado, y el propio código lo declara legado
Impacto	Cada ScanRecord guarda riskLevel y riskReasons derivados que se recalculan al leer. Datos redundantes en el sobre cifrado
Recomendación	Mantener mientras existan filtros e importaciones heredadas. No añadir nuevos consumidores

R-13 · Interfaz solo en español, con infraestructura a medias

Aspecto	Detalle
Severidad	Media · Probabilidad Alta · Prioridad P3
Ubicación	<code>lib/core/localization/app_localizations.dart</code> y todas las pantallas
Evidencia	Comprobado: la clase tiene 10 cadenas; el resto son literales en el código
Impacto	No se puede ofrecer inglés sin dejar la interfaz a medio traducir. Ya hay una prueba que impide exponerlo por accidente
Recomendación	Migrar las cadenas a AppLocalizations de forma incremental, empezando por las pantallas más pequeñas

R-14 · Sin umbral de cobertura

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P3

Ubicación	<code>.github/workflows/flutter-ci.yml</code>
Evidencia	Comprobado: se genera <code>lcov.info</code> y se sube, pero no se evalúa
Impacto	La cobertura puede caer sin que nada falle
Recomendación	Fijar un umbral por debajo del valor actual y subirlo poco a poco

Severidad baja

R-15 · `PayloadCipher.legacyKeyId` es idéntico a `currentKeyId`

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: ambos valen <code>'v2'</code>
Impacto	Un sobre heredado sin campo <code>version</code> se interpreta con la llave <code>v2</code> . Si alguna vez existió otra llave, esa distinción se perdió
Recomendación	Documentar por qué coinciden, o unificarlos

R-16 · `AppLanguage.en` es inalcanzable desde la interfaz

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: el desplegable lo convierte a «Sistema»
Impacto	Un valor del enum que ninguna ruta de la interfaz puede producir
Recomendación	Es la solución correcta al problema de la traducción parcial. Conservar hasta completar R-13

R-17 · `ScanRecord.fromJson` confía por defecto

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: <code>trustDerivedAnalysis = true</code> por defecto
Impacto	Es correcto para la base propia y peligroso para un archivo externo. Un llamante nuevo que olvide el parámetro abre el agujero
Mitigación	<code>verify_rootcause_contract.py</code> comprueba que la importación pasa <code>false</code>

Recomendación	Invertir el valor por defecto a <code>false</code> y exigir <code>true</code> explícito en el repositorio
---------------	---

R-18 · El portapapeles no se limpia si la aplicación muere

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: el temporizador vive en el proceso
Impacto	Una carga sensible copiada permanece en el portapapeles del sistema
Recomendación	Documentarlo en la interfaz. Una solución real exigiría un servicio en segundo plano, contrario al diseño

R-19 · El identificador de un registro depende del reloj

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: <code>id = SHA-256(carga\ microsegundos)</code>
Impacto	Un reloj mal ajustado produce ids con instantes incorrectos, que además viajan a la evidencia. No hay colisión práctica, pero sí desorden temporal
Recomendación	Aceptable. Documentar que el instante procede del dispositivo y no está verificado

Riesgos operativos, no de código

Id	Riesgo	Severidad	Nota
O-01	El APK se firma con la clave de depuración de Flutter	Alta	Impide una actualización sobre una copia firmada de otra forma y no acredita identidad. Declarado en toda la documentación
O-02	<code>pdf</code> y <code>excel</code> anclados por un conflicto de <code>archive</code>	Media	Un aviso de seguridad en cualquiera exigiría resolver antes el conflicto
O-03	Desinstalar equivale a perder el historial	Media	<code>allowBackup="false"</code> y llave en el Keystore. Es coherente, pero debe comunicarse
O-04	Ninguna auditoría de seguridad independiente	Media	Declarado en <code>MASVS_CHECKLIST.md</code>
O-05	Ningún escáner de vulnerabilidades ejecutado	Media	Existen SBOM e inventario de licencias; falta el escaneo

O-06	Matriz de dispositivos físicos vacía	Alta	Ninguna fila obligatoria tiene registro; declarado
O-07	Un solo mantenedor	Media	Factor bus de uno

Decisiones que requieren validación humana

Estas **no** son defectos. Son elecciones con coste que alguien debe confirmar:

1. **¿Los contactos deben persistirse?** (R-03) Es una decisión de privacidad, no técnica.
2. **¿1920×1080 es la resolución correcta?** (R-05) Hay que medir batería y temperatura en gama baja antes de fijarla.
3. **¿Debe firmarse la evidencia?** (R-04) Añade gestión de claves a un producto que hoy no la tiene.
4. **¿Merece la pena FLAG_SECURE?** (R-11) Protege, pero impide capturas de soporte.
5. **¿Se completa la traducción?** (R-13) Abre el producto a más personas y multiplica el mantenimiento de cadenas.
6. **¿Se busca firma comercial y publicación en tienda?** (O-01) Cambia el modelo de distribución y exige cuentas de desarrollador.

Lo que está bien y conviene no romper

Un informe de deuda que solo enumera problemas da una imagen falsa. Estas propiedades son sólidas y merecen protección explícita:

Fortaleza	Por qué importa
El motor es puro y no depende de Flutter	Permite probar sin dispositivo y reutilizar
Los identificadores de regla son neutrales al idioma	Traducir no rompe el formato de evidencia
Un registro ilegible se aísla, no se borra	Ningún dato se pierde por un fallo de lectura
Una llave ausente nunca se recrea	Evita la pérdida silenciosa e irreversible
La migración verifica antes de borrar el origen	El patrón correcto, aplicado
Todo campo derivado de un respaldo se recalcula	Cierra la inyección de veredictos
La evidencia omite <code>effectiveUri</code> por defecto	Cierra la reconstrucción del secreto por vía secundaria
Los verificadores offline fallan ante una regresión de contrato	Convierten decisiones documentales en gates ejecutables
Los límites se declaran como datos, no como prosa	<code>limitations</code> viaja en el JSON
El código explica por qué , no qué	Los comentarios documentan decisiones, no líneas